LAB 07 REPORT

Multi-Role User System (API + UI)

Name: Rohan Vij
Enrollment No: CS-2341127
Section: 3CSE15
Subject: Web Technologies
Submission Date: 03/03/2026

GitHub Repository Link:
https://github.com/ROHANVIJ2006/Web_Technologies

Contents

1 Introduction **2**

2 Database Verification **3**

3 Authentication API Testing **4**

4 Authorization and RBAC Testing **7**

5 Frontend Role-Based Dashboards **15**

6 Conclusion **18**

Chapter 1

Introduction

This lab implements a secure Multi-Role Authentication and Authorization system using JWT and Role-Based Access Control (RBAC).

Technologies used:

- Node.js + Express
- MongoDB
- JWT Authentication
- React.js Frontend

Roles implemented:

- SUPER_ADMIN
- ADMIN
- USER

Chapter 2

Database Verification

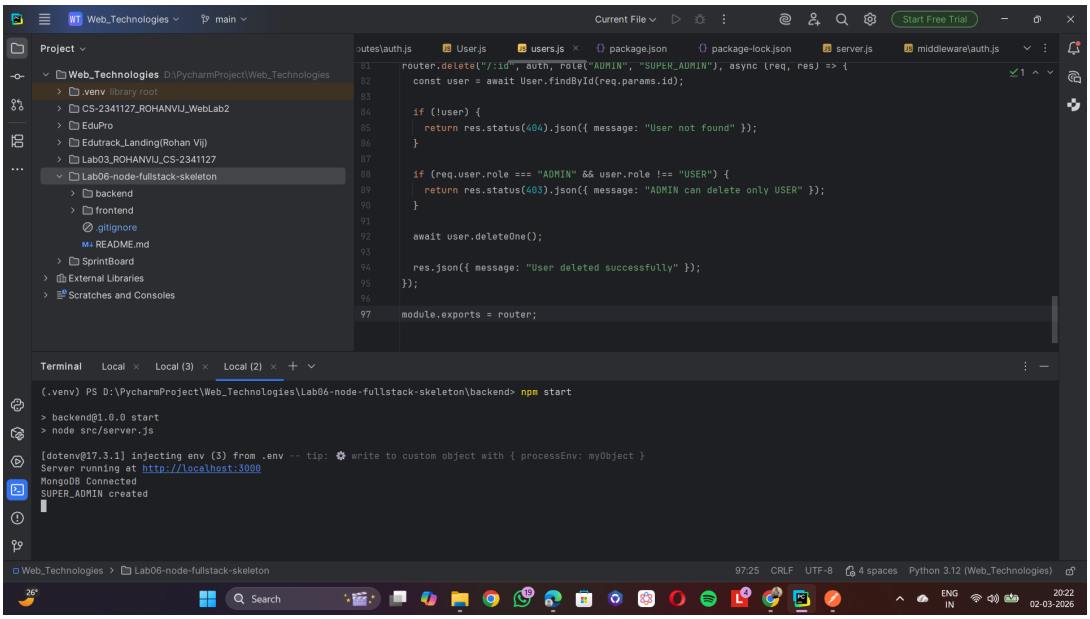

Figure 2.1: MongoDB Database (mongo_superbase)

Explanation: The MongoDB database stores users with encrypted passwords and assigned roles (SUPER_ADMIN, ADMIN, USER).

Chapter 3

Authentication API Testing

User Registration

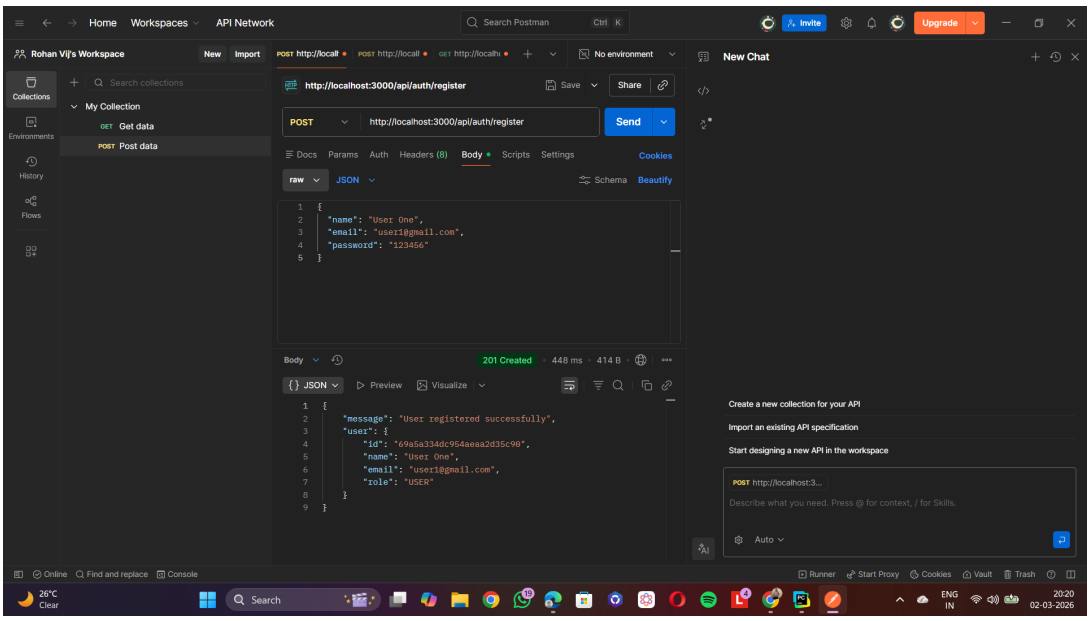

Figure 3.1: POST /api/auth/register creates USER

Explanation: A new USER is successfully created using the public registration endpoint.

User Login

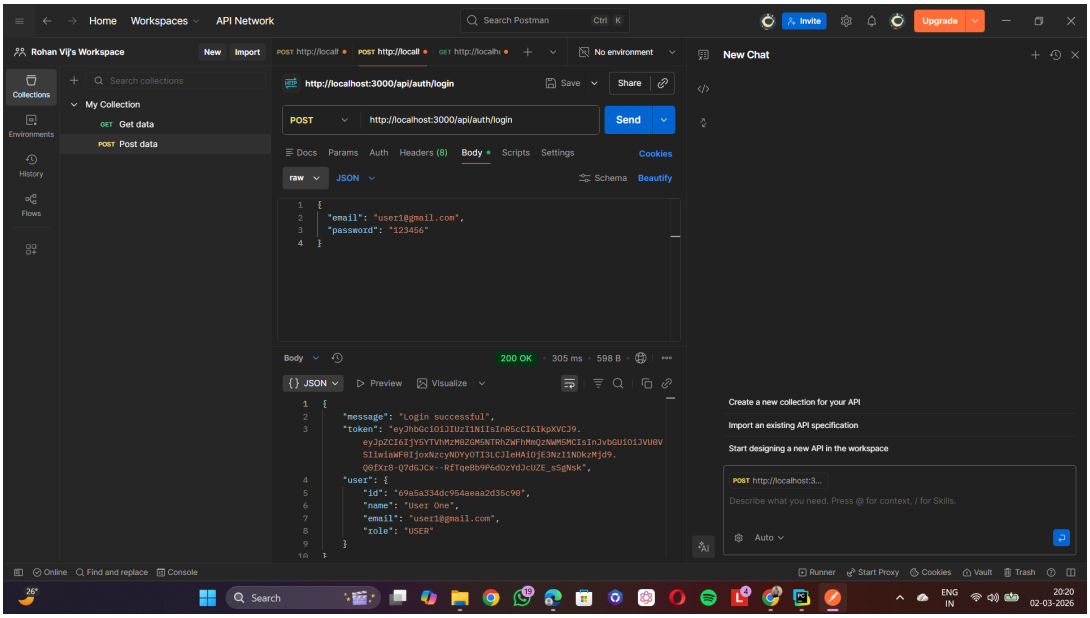

Figure 3.2: POST /api/auth/login

Explanation: Login returns a valid JWT token for authentication.

Get Current User Profile

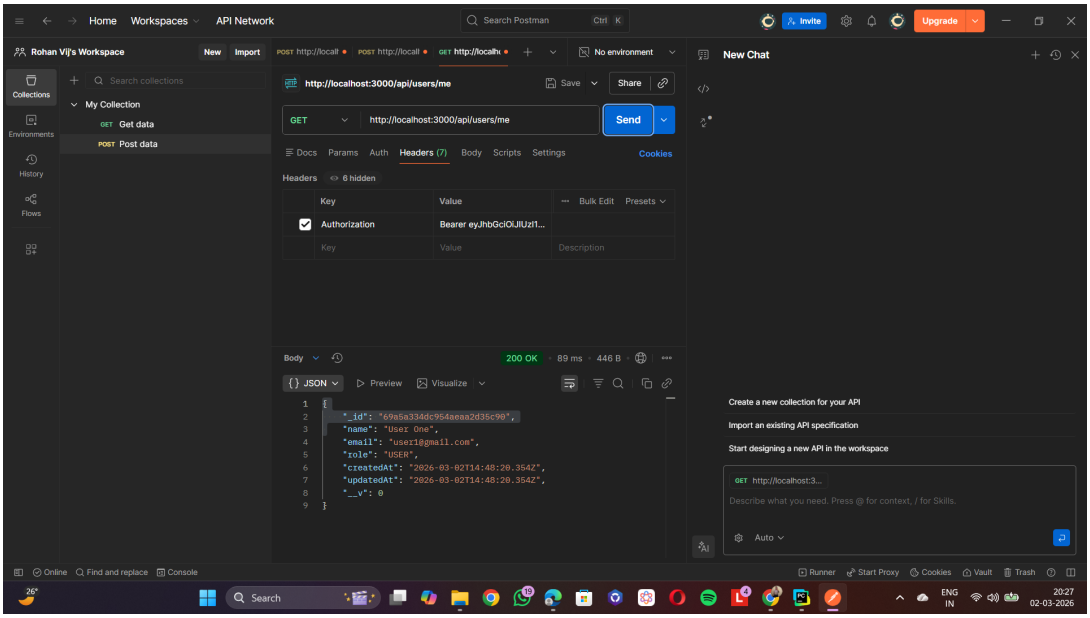

Figure 3.3: GET /api/users/me

Explanation: Authenticated users can retrieve their own profile using JWT.

Chapter 4

Authorization and RBAC Testing

USER Access Restriction

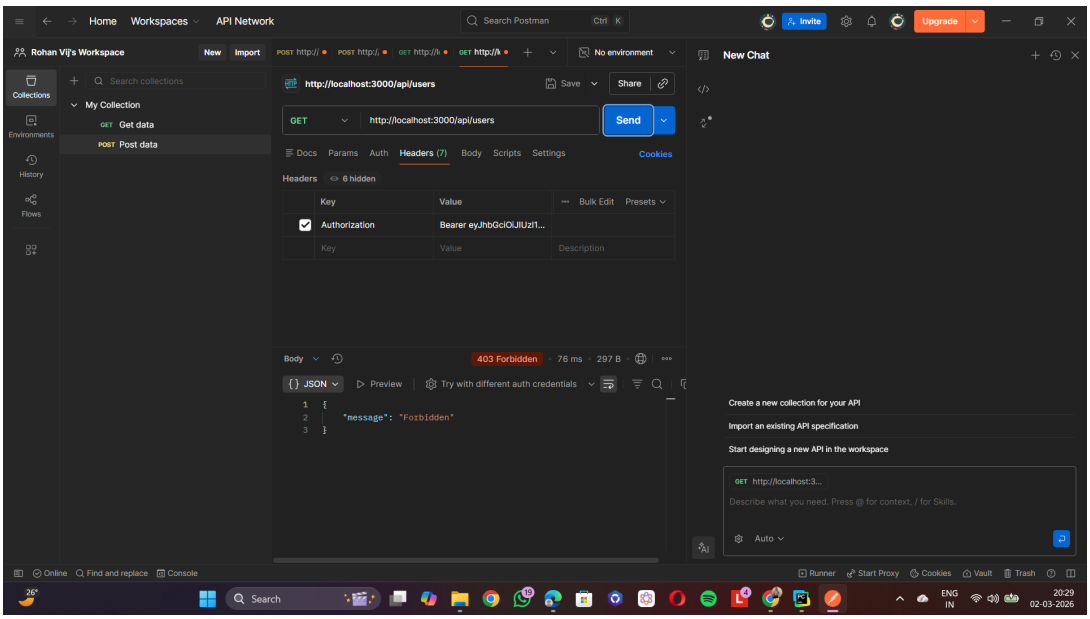

Figure 4.1: GET /api/users returns 403

Explanation: USER attempting to access admin-level endpoint receives 403 Forbidden.

SUPER_ADMIN Listing All Users

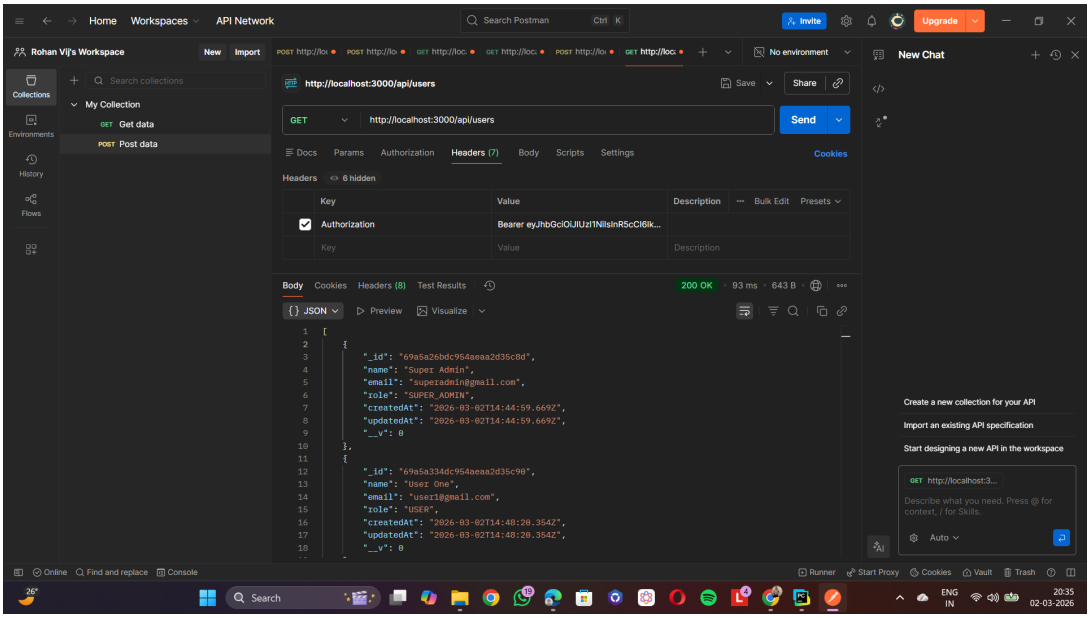

Figure 4.2: GET /api/users by SUPER_ADMIN

Explanation: SUPER_ADMIN can view all users in the system.

SUPER_ADMIN Creating New ADMIN

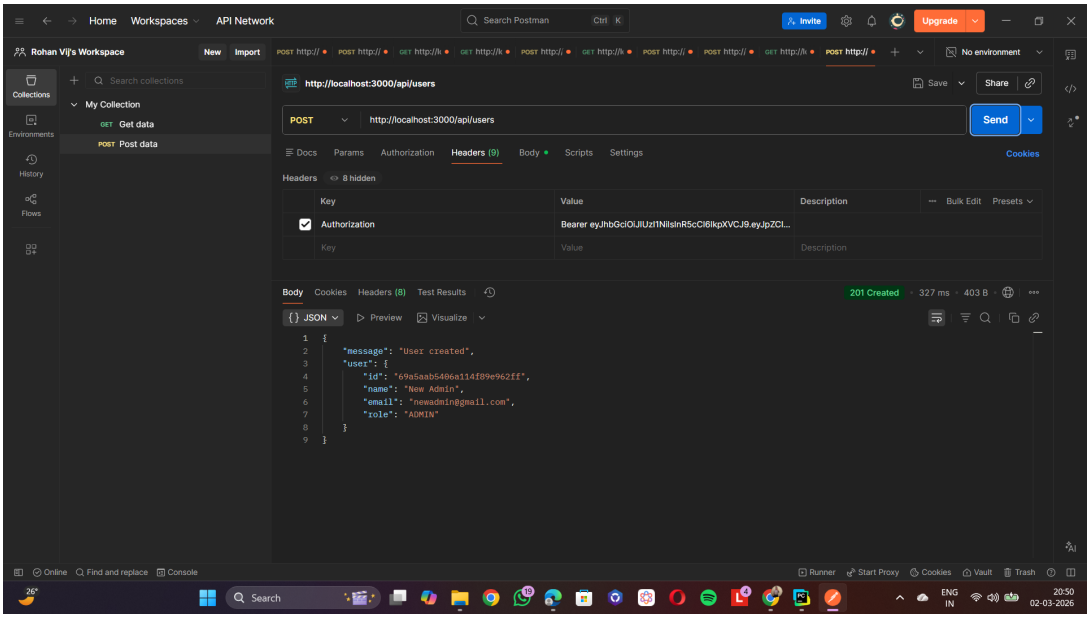

Figure 4.3: SUPER_ADMIN Creates ADMIN

Explanation: SUPER_ADMIN successfully creates a new ADMIN account.

ADMIN Cannot Create ADMIN

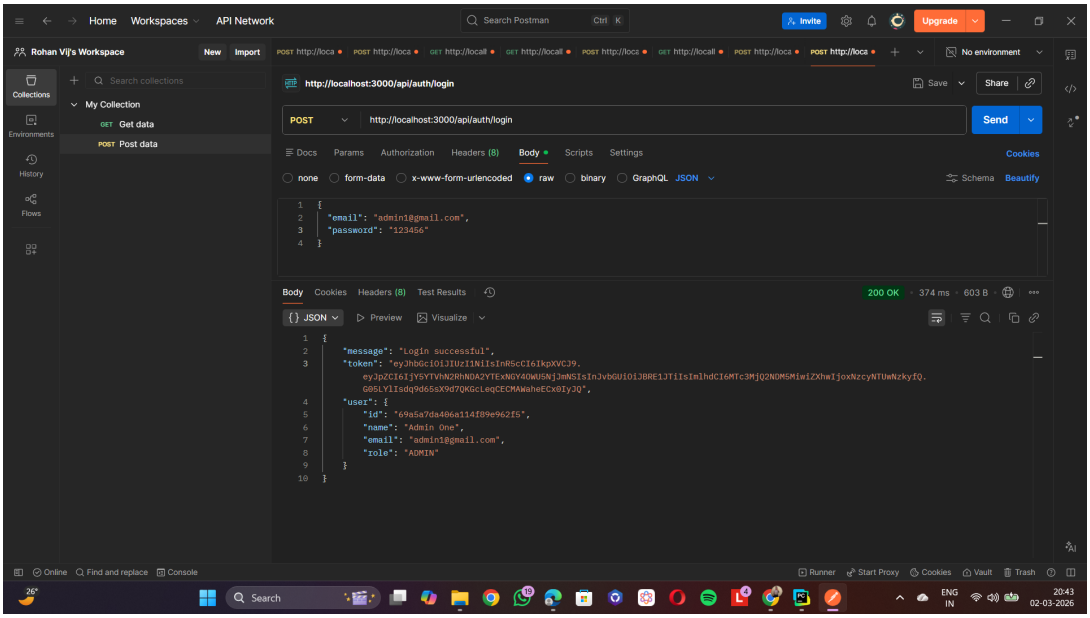

Figure 4.4: ADMIN Cannot Create ADMIN (403)

Explanation: ADMIN attempting to create another ADMIN receives 403 Forbidden.

ADMIN Cannot Delete ADMIN

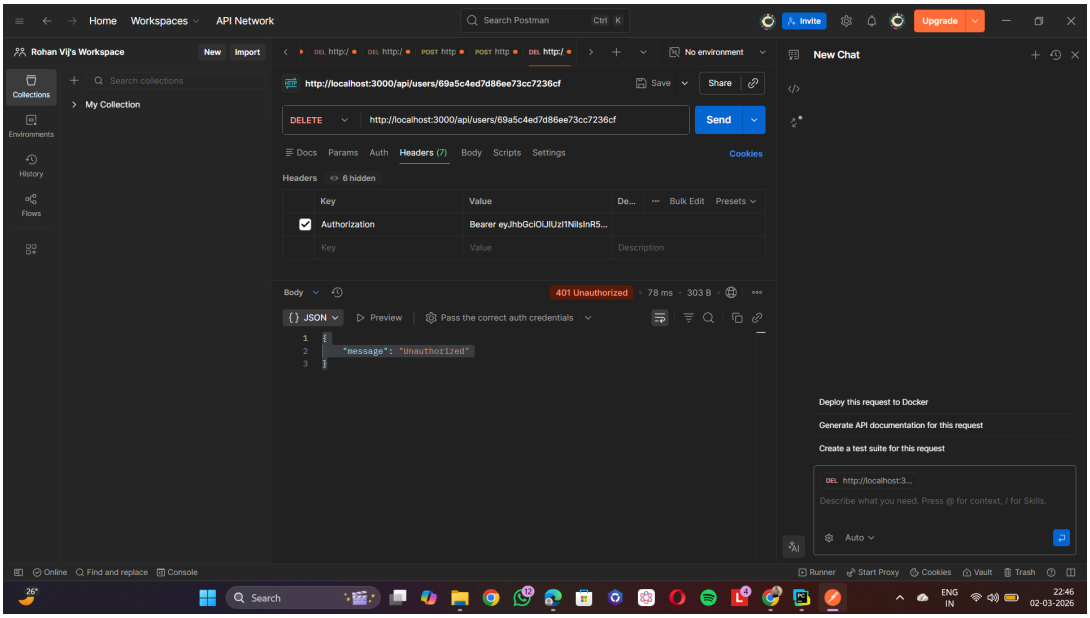

Figure 4.5: ADMIN Cannot Delete ADMIN (403)

Explanation: ADMIN cannot delete another ADMIN due to hierarchy restrictions.

ADMIN Deleting USER

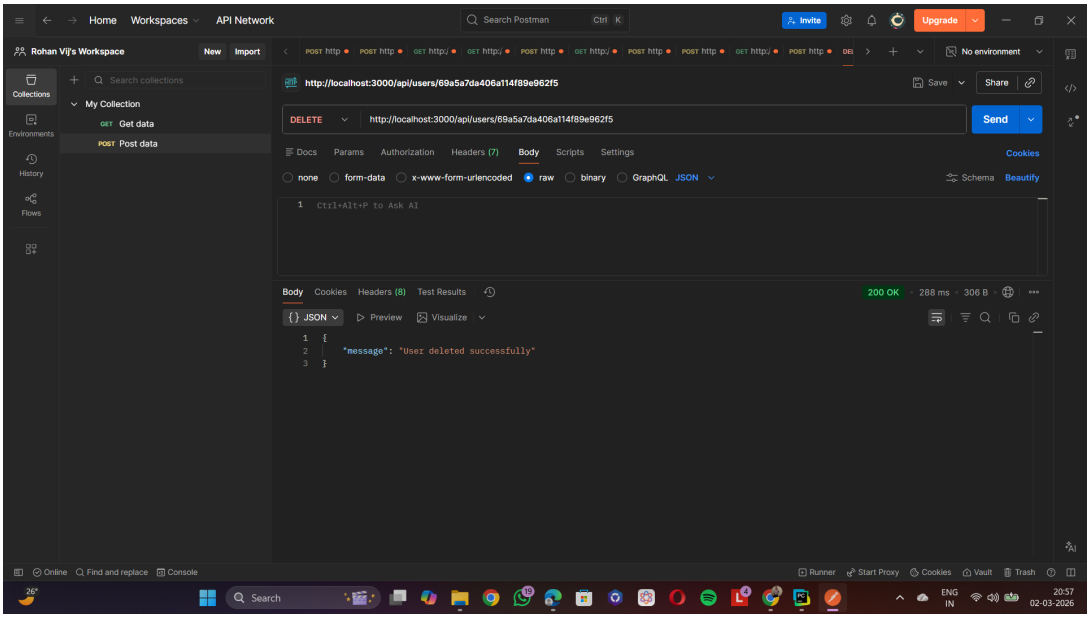

Figure 4.6: ADMIN Deleting USER Successfully

Explanation: ADMIN is allowed to delete USER accounts.

SUPER_ADMIN Deleting ADMIN

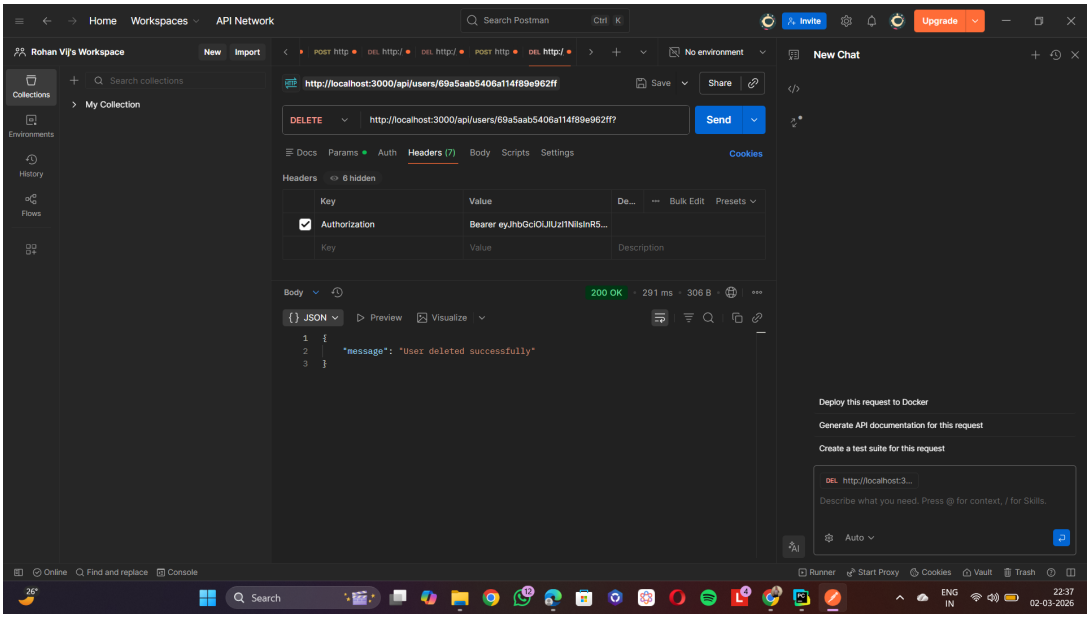

Figure 4.7: SUPER_ADMIN Deleting ADMIN Successfully

Explanation: SUPER_ADMIN can delete ADMIN accounts as highest authority.

ADMIN Listing Only USER Accounts

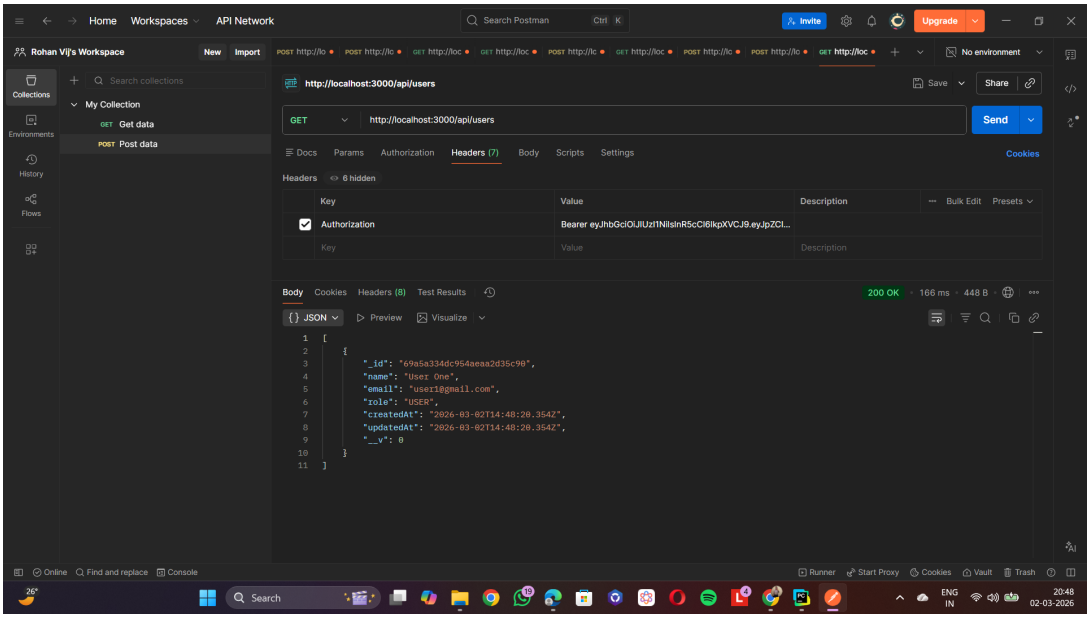

Figure 4.8: ADMIN Listing Only USER Accounts

Explanation: ADMIN can view USER accounts but not SUPER_ADMIN accounts.

Chapter 5

Frontend Role-Based Dashboards

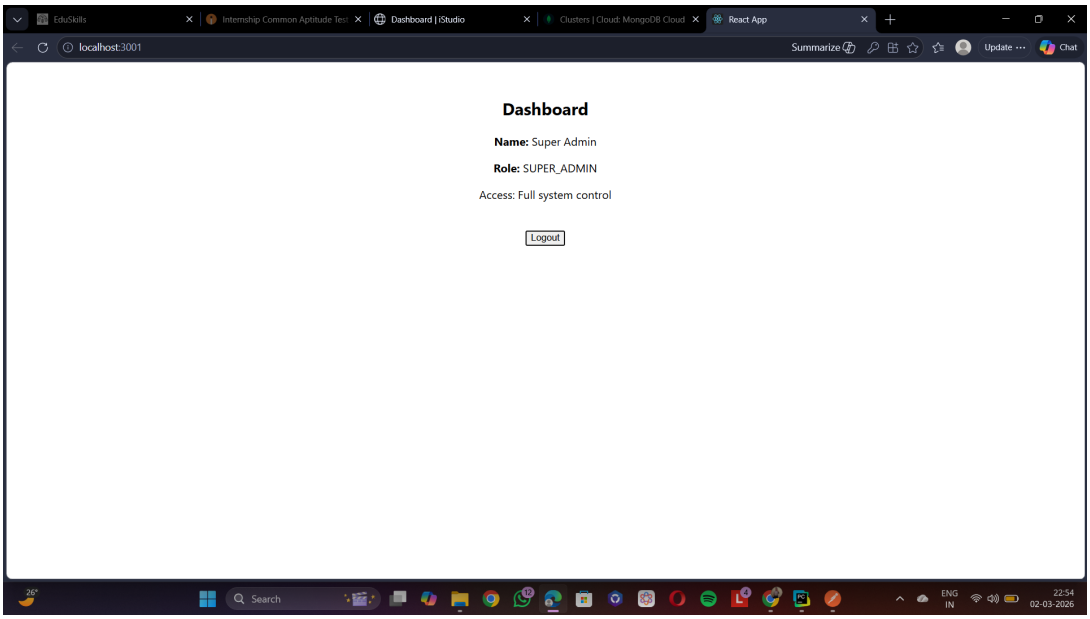

Figure 5.1: SUPER_ADMIN Dashboard

Explanation: Full system access interface for SUPER_ADMIN.

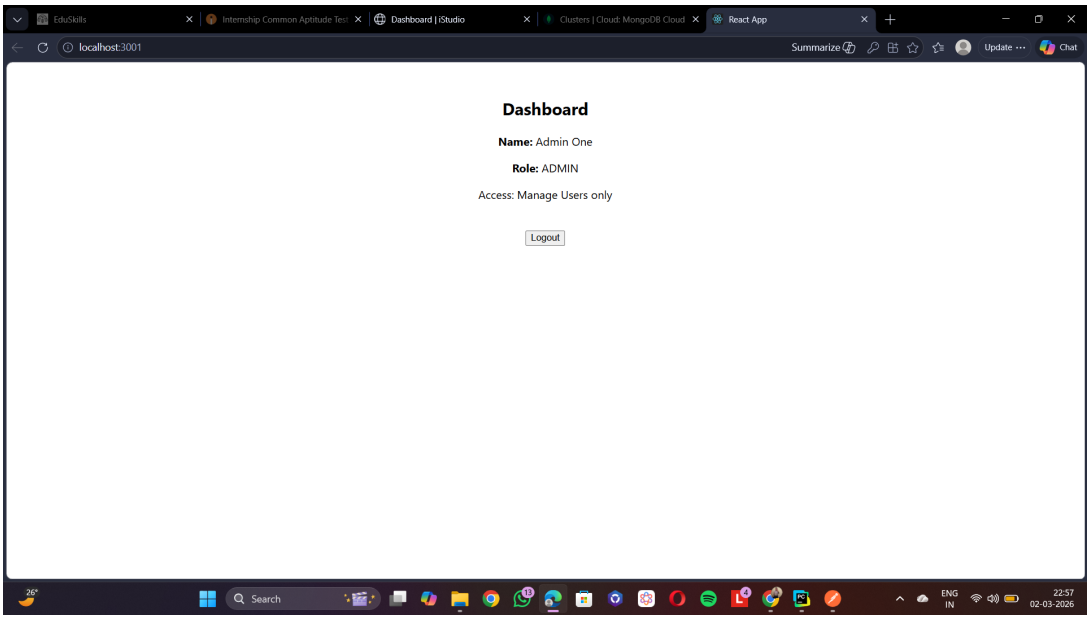

Figure 5.2: ADMIN Dashboard

Explanation: ADMIN dashboard allows management of USER accounts only.

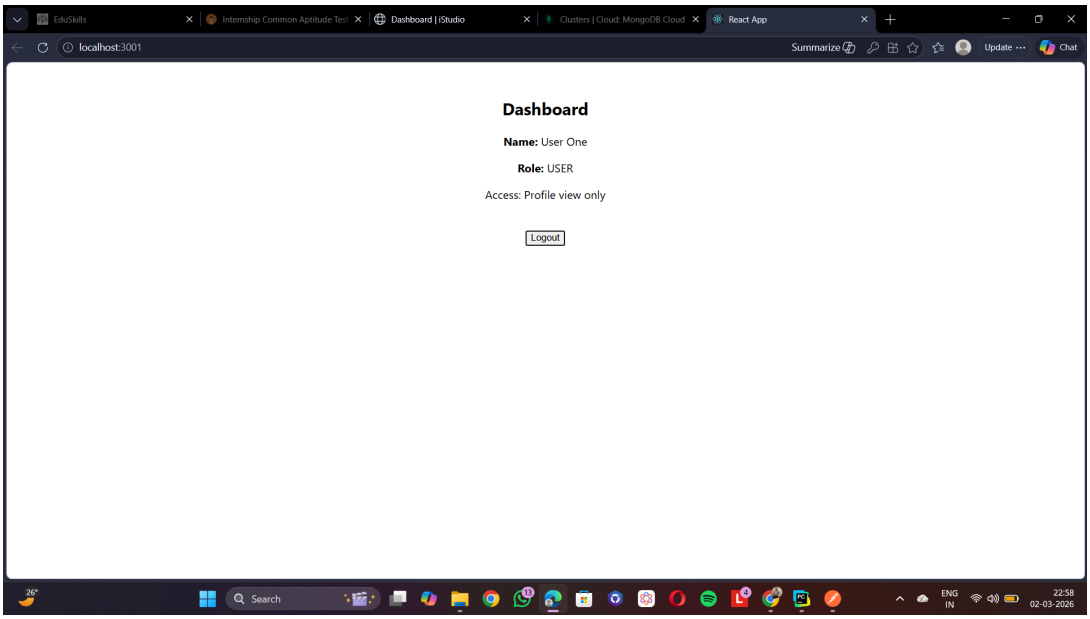

Figure 5.3: USER Dashboard

Explanation: USER dashboard allows viewing personal profile information only.

Chapter 6

Conclusion

This lab successfully implemented a secure JWT-based Role-Based Access Control system.

All permissions were validated using Postman and frontend UI testing. Proper HTTP status codes such as 401 Unauthorized and 403 Forbidden were correctly implemented.

The system demonstrates secure backend architecture and dynamic frontend rendering based on user roles.